Anleitung: M365-Sicherheits-Checkliste automatisch befüllen

Ziel: Mit dem Skript `Invoke-M365SecurityAssessment.ps1` die Einstellungen eines Tenants auslesen und die Ergebnisse (Ist-Wert + Status) automatisch in die Excel-Checkliste schreiben.

Was gehört zusammen - **Ein** PowerShell-Skript: `Invoke-M365SecurityAssessment.ps1` (Die Datei `….ps1.txt` ist nur eine Download-Ersatzkopie mit identischem Inhalt – nach dem Download in `.ps1` umbenennen. Es gibt kein zweites Skript.) - **Eine** Excel-Datei: `M365_BusinessPremium_Sicherheit_Checkliste_v1.2.xlsx` → **v1.2 ist der aktuelle Stand** (eure 111-Punkte-Checkliste + Blatt „Auslese-Mapping").

Wichtig: Das Skript ist **read-only** – es verändert nichts im Tenant. Es liest nur und schreibt ausschließlich in eine **Kopie** der Excel.

---

1. Einmalige Vorbereitung

1a. Module installieren

In einer PowerShell-Konsole (PowerShell 7 **oder** Windows PowerShell 5.1):

```
Install-Module Microsoft.Graph, ExchangeOnlineManagement, ImportExcel -Scope CurrentUser
```

1b. Konto mit Leserechten

Melde dich später mit einem Konto an, das **Global Reader** hat (deckt Graph-Lesezugriff und Exchange/Security-&-Compliance-Lesezugriff ab). Reines Lesen – kein Schreibrecht nötig.

1c. Graph-Zustimmung (nur beim ersten Mal / einmal pro Tenant)

Das Skript fordert die Lese-Scopes selbst an. Wenn in eurem Tenant die **Nutzer-Zustimmung eingeschränkt** ist (das empfiehlt Punkt A-18!), muss ein **Global Admin einmalig** der App „Microsoft Graph Command Line Tools" zustimmen. Danach genügt das Global-Reader-Konto.

---

2. Dateien ablegen

Lege beide Dateien in denselben Ordner, z. B. `C:\M365-Check\`:

```
C:\M365-Check\
   Invoke-M365SecurityAssessment.ps1
   M365_BusinessPremium_Sicherheit_Checkliste_v1.2.xlsx
```

Falls Windows das Skript als „aus dem Internet" blockiert, einmalig entsperren:

```
Unblock-File C:\M365-Check\Invoke-M365SecurityAssessment.ps1
```

---

3. Skript ausführen (ein Tenant, interaktiv)

PowerShell im Ordner öffnen und ausführen – **-ChecklistPath muss auf die .xlsx-DATEI zeigen, nicht auf den Ordner**:

```
cd C:\M365-Check
.\Invoke-M365SecurityAssessment.ps1 -ChecklistPath ".\M365_BusinessPremium_Sicherheit_Checkliste_v1.2.xlsx"
```

Falls die Ausführungsrichtlinie meckert, alternativ:

```
powershell -ExecutionPolicy Bypass -File .\Invoke-M365SecurityAssessment.ps1 -ChecklistPath
".\M365_BusinessPremium_Sicherheit_Checkliste_v1.2.xlsx"
```

Was dann passiert: 1. Es öffnen sich nacheinander Anmeldefenster für **Graph**, **Exchange Online** und **Security & Compliance**. Mit dem Global-Reader-Konto anmelden. 2. In der Konsole laufen die Checks durch (grün = Erledigt, gelb = Teilweise, rot = Offen, grau = n.a.). 3. Am Ende steht eine Zusammenfassung und der Pfad zur Ergebnisdatei.

---

4. Was das Skript in die Excel schreibt

Es befüllt im Blatt **„Checkliste"** je Zeile (gematcht über die Spalte **„Nr."**):

Spalte	Inhalt
H – Ist-Wert / Konfiguriert	Auswertungstext mit Zeitstempel, z. B. `[Auto 2026-10-14 09:15] Security Defaults isEnabled=False; aktive CA-Richtlinien: 4`
I – Status	`Erledigt` · `Teilweise` · `Offen` · `n.a.` (passt zum vorhandenen Dropdown)

Unverändert bleiben: eure Spalte **J (Bemerkung)**, das Blatt **„Auslese-Mapping"**, das Blatt **„Anhang ASR-Regeln"** und die komplette Formatierung.

Punkte ohne automatischen Check (z. B. Sektion E „Betrieb & Nachweisführung", einzelne Defender-Detaileinstellungen) werden **ausdrücklich markiert**: In Spalte H steht dann `[Auto …] Kein automatischer Check - manuell zu pruefen (siehe Blatt 'Auslese-Mapping')`. So bleibt nach dem Lauf **kein Feld leer** – man sieht sofort, was von Hand gehört. Bereits **manuell eingetragene** Ist-Werte werden dabei **nicht** überschrieben.

---

5. Ergebnis öffnen und abarbeiten

Das Skript legt standardmäßig eine **datierte Kopie** an (Original bleibt unberührt):

```
M365_BusinessPremium_Sicherheit_Checkliste_v1.2_ausgewertet_<JJJJMMTT-HHMM>.xlsx
```

Diese Datei öffnen, Blatt „Checkliste", dann: 1. Nach **Status = „Offen"** filtern → das sind die konkreten Handlungspunkte. 2. Die **gelben** („Teilweise") durchsehen – Ist-Wert in Spalte H gibt den tatsächlichen Wert an. 3. Die als **„Kein automatischer Check"** markierten Zeilen (Spalte H) von Hand bearbeiten – das sind die 58 Punkte, die nicht automatisiert auslesbar sind (Prozess- und Detailpunkte).

Nach dem Lauf ist **kein Ist-Wert-Feld leer**: 53 Punkte sind automatisch befüllt, die übrigen 58 tragen den „manuell zu prüfen"-Vermerk.

---

6. Nützliche Optionen

Option	Wirkung
(ohne)	Erzeugt eine datierte Kopie neben der Eingabedatei (empfohlen).
`-InPlace`	Schreibt **direkt** in die angegebene Datei (keine Kopie).
`-OutputPath "C:\...\Ergebnis.xlsx"`	Schreibt in genau diese Zieldatei.
`-Domains cadocare.com,shop.cadocare.com`	Gibt die Domänen für SPF/DMARC vor (schließt z. B. die CodeTwo-Service-Subdomäne aus, die sonst DMARC „Offen" auslöst).
`-SkipCompliance` / `-SkipExchange` / `-SkipGraph` / `-SkipDns`	Einzelne Bereiche überspringen.

Auf dem vorherigen Lauf aufbauen: Wenn du die Ergebnisse weiterpflegen willst, gib beim nächsten Lauf die **letzte Ergebnisdatei** als `-ChecklistPath` an (oder arbeite mit `-InPlace` auf einer Arbeitskopie). Sonst startet jeder Lauf von der sauberen v1.2.

---

7. MSP / mehrere Tenants (app-only)

Gleiche Checks, nur ein anderer Anmelde-Block – für unbeaufsichtigten Betrieb:

```
.\Invoke-M365SecurityAssessment.ps1 -ChecklistPath ".\Checkliste.xlsx" `
    -AppOnly -TenantId contoso.onmicrosoft.com -ClientId <App-ID> -CertificateThumbprint <Thumbprint>
```

Voraussetzung: einmalig eine App-Registrierung mit den **Application**-Leseberechtigungen + Zertifikat anlegen und Admin-Consent erteilen; die App zusätzlich mit einer Exchange-Leserolle als Dienstprinzipal hinterlegen.

---

8. Turnus (Punkt E-06)

Die Checkliste ist als wiederkehrende Kontrolle gedacht. Empfehlung: **halbjährlich** laufen lassen und das Datum der nächsten Prüfung im Blatt „Info & Legende" eintragen.

---

9. Troubleshooting

Meldung / Symptom	Ursache & Lösung
`Blatt 'Checkliste' nicht gefunden` bzw. Abbruch am Ende	`-ChecklistPath` zeigt auf einen **Ordner** statt die **.xlsx-Datei**. Vollständigen Dateipfad angeben. (Das Skript prüft das inzwischen vorab und bricht mit klarer Meldung ab.)
`Unerwartetes Token "?"` / `"??"`	Altes Skript auf Windows PowerShell 5.1. Die **aktuelle** Fassung ist 5.1-kompatibel – die neueste Version verwenden.
Umlaute kaputt (`â€¦`)	Alte Datei ohne BOM. Aktuelle Fassung ist UTF-8 mit BOM – neueste Version verwenden.
`…nicht eindeutig lesbar - im Profil pruefen` (Intune)	Der Wert ist evtl. per **Baseline/Intent** statt Settings-Catalog gesetzt. Kein Fehler – im Intune-Profil gegenprüfen; auf Wunsch passe ich die Settings-IDs an eure Profile an.
Eine Engine meldet „nicht verbunden"	Anmeldung für diesen Bereich abgebrochen/fehlgeschlagen. Betroffene Punkte stehen auf „manuell prüfen"; Lauf wiederholen oder mit `-Skip…` gezielt auslassen.
`Failed to clear the persisted MSAL token cache`	Harmlose Warnung beim Graph-Disconnect – ohne Auswirkung (in der aktuellen Fassung unterdrückt).

---

10. Abdeckung

- **53 Kontrollpunkte** werden automatisch geprüft (Entra, Intune inkl. echter Wert-Prüfung für AV/ASR/Firewall/BitLocker, Defender-for-Office/EOP, Exchange/Purview, DNS).
- Die übrigen Punkte (Sektion E, einzelne Defender-Endpoint-Feineinstellungen) bleiben bewusst manuell und werden markiert.
- Welcher Punkt wie auslesbar ist, steht im Excel-Blatt **„Auslese-Mapping"** (Methode, Auslesbar Ja/Teilweise/Nein, konkrete Quelle).